

1. Introduction

Web enumeration is a crucial skill for any penetration tester, as it uncovers hidden content that may not be directly accessible through normal browsing. The Attacking Web Applications with Ffuf module focuses on using fuzzing techniques to locate directories, files, subdomains, and parameters that could be exploited during a web application assessment. This hands-on module not only teaches the use of Ffuf but also reinforces how enumeration can reveal potential weaknesses in a target application.

2. Module Sections

```
kali@kali: ~/Downloads
File Actions Edit View Help

(kali@kali)~(~/Downloads)
$ locate directory-list-2.3-small.txt
/home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
/usr/share/dirbuster/wordlists/directory-list-2.3-small.txt

(kali@kali)~(~/Downloads)
$ ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://83.136.255.218:59730/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.255.218:59730/FUZZ
:: Wordlist     : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

forum [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 153ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1069ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2066ms]
:: Progress: [160/87664] :: Job [1/1] :: 42 req/sec :: Duration: [0:00:03] :: Errors: 0 ::

(kali@kali)~(~/Downloads)
File Actions Edit View Help

# Copyright 2007 James Fisher [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 5076ms]
# on at least 3 different hosts [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 5076ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 156ms]
:: Progress: [87664/87664] :: Job [1/1] :: 20 req/sec :: Duration: [0:06:01] :: Errors: 0 ::

(kali@kali)~(~/Downloads)
$ ffuf -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://83.136.255.218:59730/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.255.218:59730/FUZZ
:: Wordlist     : FUZZ: /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 155ms]
# Copyright 2007 James Fisher [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 155ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 157ms]
forum [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 153ms]
# Priority-ordered case-sensitive list, where entries were found [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1239ms]
:: Progress: [176/87664] :: Job [1/1] :: 79 req/sec :: Duration: [0:00:02] :: Errors: 0 ::
```

```
File Actions Edit View Help

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.255.218:59730/FUZZ
:: Wordlist     : FUZZ: /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 155ms]
# Copyright 2007 James Fisher [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 155ms]
# Attribution-Share Alike 3.0 license. To view a copy of this [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 157ms]
# forum [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 153ms]
# Priority-ordered case-sensitive list, where entries were found [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 1239ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 2318ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3246ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3246ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 3243ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4253ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4249ms]
# blog [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 4253ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4252ms]
# on at least 3 different hosts [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4253ms]
# directory-list-2.3-small.txt [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4254ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 152ms]
:: Progress: [87664/87664] :: Job [1/1] :: 164 req/sec :: Duration: [0:05:51] :: Errors: 0 ::
```

```
File Actions Edit View Help

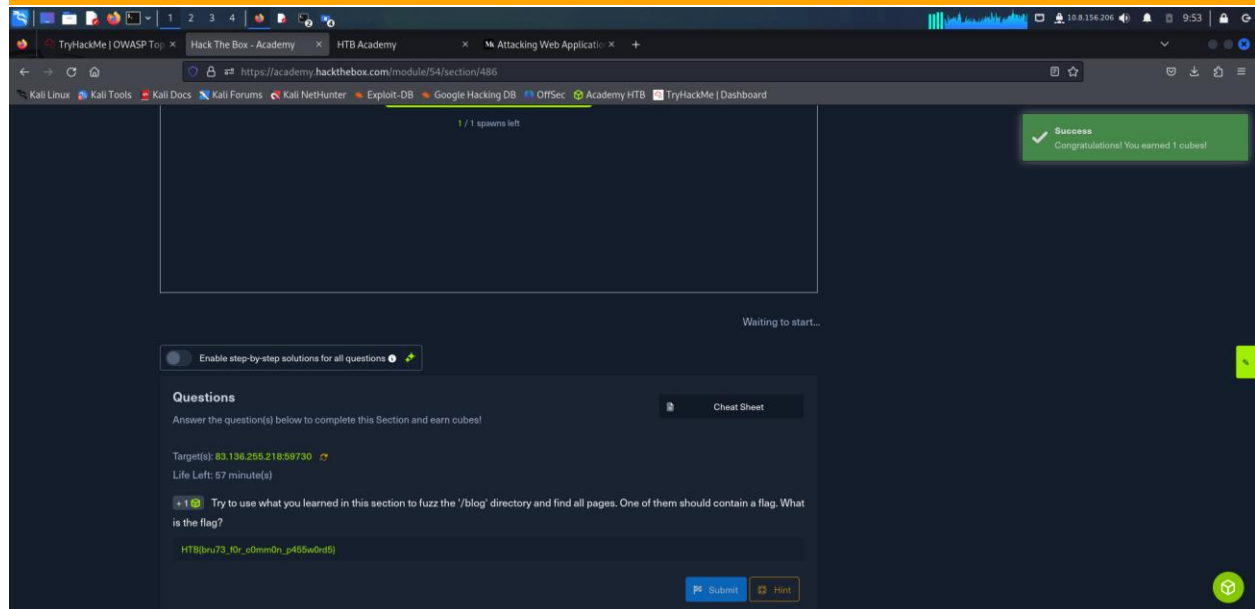
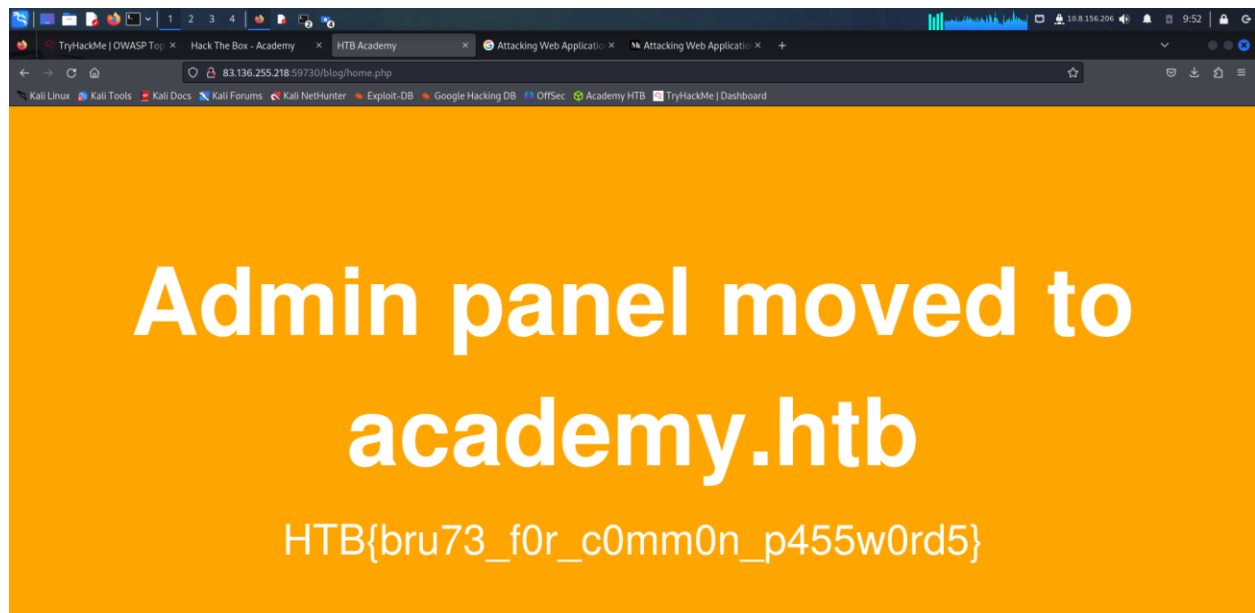
blog [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 4253ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4252ms]
# on at least 3 different hosts [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4253ms]
# directory-list-2.3-small.txt [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 4254ms]
# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 152ms]
:: Progress: [87664/87664] :: Job [1/1] :: 164 req/sec :: Duration: [0:05:51] :: Errors: 0 ::

(kali@kali)~/.Downloads
$ ffuf -ic -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://83.136.255.218:59730/blog/FUZZ.php

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.255.218:59730/blog/FUZZ.php
:: Wordlist     : FUZZ: /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

home [Status: 200, Size: 1046, Words: 438, Lines: 58, Duration: 201ms]
index [Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 3129ms]
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 5141ms]
:: Progress: [954/87651] :: Job [1/1] :: 258 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
```



```
File Actions Edit View Help
[Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 3129ms]
index [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 514ms]
[Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 160ms]
:: Progress: [87651/87651] :: Job [1/1] :: 258 req/sec :: Duration: [0:05:54] :: Errors: 0 ::

(kali@kali)~[~/Downloads]
$ ffuf -ic -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://83.136.255.218:59730/FUZZ -recursion -recursion-depth
1 -e .php -v

v2.1.0-dev

:: Method      : GET
:: URL         : http://83.136.255.218:59730/FUZZ
:: Wordlist     : FUZZ: /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
:: Extensions  : .php
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

[Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 190ms]
| URL | http://83.136.255.218:59730/.php
* FUZZ: .php

TryHackMe | OWASP Top | Hack The Box - Academy | 83.136.255.218:59730/forum | Attacking Web Application | New Tab
83.136.255.218:59730/forum/flag.php
Kali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | OffSec | Academy HTB | TryHackMe | Dashboard
HTB{fuzzln6_7h3_w3b!}
```

```
File Actions Edit View Help

[INFO] Adding a new job to the queue: http://83.136.255.218:59730/blog/FUZZ

[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 451ms]
| URL | http://83.136.255.218:59730/
* FUZZ:

[Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 159ms]
| URL | http://83.136.255.218:59730/.php
* FUZZ: .php

[Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 158ms]
| URL | http://83.136.255.218:59730/
* FUZZ:

[INFO] Starting queued job on target: http://83.136.255.218:59730/forum/FUZZ

[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 155ms]
| URL | http://83.136.255.218:59730/forum/
* FUZZ:

[Status: 403, Size: 282, Words: 20, Lines: 10, Duration: 154ms]
| URL | http://83.136.255.218:59730/forum/.php
* FUZZ: .php

[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 181ms]
| URL | http://83.136.255.218:59730/forum/index.php
* FUZZ: index.php

[Status: 200, Size: 21, Words: 1, Lines: 1, Duration: 159ms]
| URL | http://83.136.255.218:59730/forum/flag.php
* FUZZ: flag.php

:: Progress: [29351/175302] :: Job [2/3] :: 223 req/sec :: Duration: [0:01:57] :: Errors: 0 ::
```

TryHackMe | OWASP Top

Hack The Box - Academy

83.136.255.218:59730/forum

Attacking Web Application

New Tab

https://academy.hackthebox.com/module/54/section/483

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

Waiting to start...

Success
Congratulations! You earned 1 cubes!

☐ Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Cheat Sheet

Target(s): 83.136.255.218:59730

Life Left: 38 minute(s)

Try to repeat what you learned so far to find more files/directories. One of them should give you a flag. What is the content of the flag?

HTB(huzz1n6_7h3_w3b)

SubmitHint

PreviousNext

+10 Streak ptsMark Complete & Next

Powered by HACK THE BOX

```
File Actions Edit View Help
kali@kali: ~/Downloads
$ locate subdomains-topmillion-5000.txt
/home/kali/SecLists/Discovery/DNS/subdomains-topmillion-5000.txt

kali@kali:~/Downloads
$ ffuf -w /home/kali/SecLists/Discovery/DNS/subdomains-topmillion-5000.txt:FUZZ -u https://FUZZ.inlane freight.com

v2.1.0-dev

:: Method      : GET
:: URL         : https://FUZZ.inlane freight.com
:: Wordlist     : FUZZ: /home/kali/SecLists/Discovery/DNS/subdomains-topmillion-5000.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [40/4989] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:02] :: Errors: 0 ::
```

TryHackMe | OWASP Top

Hack The Box - Academy

Medium

https://academy.hackthebox.com/module/54/section/488

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

Success
Congratulations! You earned 0 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

+0

Try running a sub-domain fuzzing test on 'inlane freight.com' to find a customer sub-domain portal. What is the full domain of it?

customer.inlane freight.com

Submit Hint

Previous

Next

+10 Streak pts

Mark Complete & Next

Powered by HACK THE BOX

```
(kali@kali)-[~/Downloads]
$ locate subdomains-topmillion-5000.txt
/home/kali/SecLists/Discovery/DNS/subdomains-topmillion-5000.txt

(kali@kali)-[~/Downloads]
$ ffuf -w //home/kali/SecLists/Discovery/DNS/subdomains-topmillion-5000.txt:FUZZ -u http://94.237.60.55:31365/ -H 'Host: FUZZ.academy.htb'
Keyword FUZZ defined, but not found in headers, method, URL or POST data.

v2.1.0-dev

:: Method      : GET
:: URL         : http://94.237.60.55:31365/
:: Header      : 'Host:
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [1/1] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 1 ::

(kali@kali)-[~/Downloads]
$
```

Hack The Box - Academy

VPN Settings

https://academy.hackthebox.com/module/54/section/502

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

Success
Congratulations! You earned 0 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.60.55:31365

Life Left: 60 minute(s)

Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?

test.academy.htb

SubmitHint

PreviousNext

+10 Streak ptsMark Complete & Next


```
kali@kali -  
File Actions Edit View Help  
PUBL [Status: 200, Size: 798, Words: 227, Lines: 54, Duration: 156ms]  
[WARN] Caught keyboard interrupt (Ctrl-C)  
  
kali@kali ~$ ffuf -w /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt -u http://admin.academy.htb:31365/admin/admin.php?FUZZ=key -fs 798  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://admin.academy.htb:31365/admin/admin.php?FUZZ=key  
:: Wordlist : FUZZ: /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 798  
  
user [Status: 200, Size: 783, Words: 221, Lines: 54, Duration: 156ms]  
:: Progress: [6453/6453] :: Job [1/1] :: 260 req/sec :: Duration: [0:00:28] :: Errors: 0 ::  
  
kali@kali ~$
```

Success
Congratulations! You earned 9 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.60.55:31365
Life Left: 54 minute(s)

Using what you learned in this section, run a parameter fuzzing scan on this page. What is the parameter accepted by this webpage?

user

Submit

Previous Next

+10 Streak pts Mark Complete & Next

Powered by HACKTHEBOX


```
kali@kali ~  
File Actions Edit View Help  
19 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 3477ms]  
170 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 213ms]  
[WARN] Caught keyboard interrupt (Ctrl-C)  
  
└─(kali@kali)-[~]  
└─$ ffuf -w ids.txt:FUZZ -u http://admin.academy.htb:37935/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 768  
  
v2.1.0-dev  
  
:: Method : POST  
:: URL : http://admin.academy.htb:37935/admin/admin.php  
:: Wordlist : FUZZ: /home/kali/ids.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Data : id=FUZZ  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 768  
  
73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 204ms]  
:: Progress: [128/1000] :: Job [1/1] :: 61 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

```
kali@kali ~  
File Actions Edit View Help  
└─(kali@kali)-[~]  
└─$ curl http://admin.academy.htb:37935/admin/admin.php -X POST -d 'id=73' -H 'Content-Type: application/x-www-form-urlencoded'  
<div class="center"><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>  
<html>  
<!DOCTYPE html>  
  
<head>  
<title>HTB Academy</title>  
<style>  
*,  
html {  
margin: 0;  
padding: 0;  
border: 0;  
}  
  
html {  
width: 100%;  
height: 100%;  
}  
  
body {  
width: 100%;  
height: 100%;  
position: relative;  
background-color: darkslategrey;  
}  
  
.center {  
width: 100%;  
height: 50%;  
margin: 0;  
position: absolute;  
top: 50%;  
}
```

VPN Settings

1 2 3 4

https://academy.hackthebox.com/module/54/section/505

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

1 / 1 spawns left

Success
Congratulations! You earned 1 cubes!

Waiting to start...

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.58.50:37935

Life Left: 85 minute(s)

1 Try to create the 'ids.txt' wordlist, identify the accepted value with a fuzzing scan, and then use it in a 'POST' request with 'curl' to collect the flag. What is the content of the flag?

HTB(p4r4m373r_fuzz1n6_15_k3y0)

Submit Hint

VPN Settings

1 2 3 4

https://academy.hackthebox.com/module/54/section/511

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.58.50:41149

Life Left: 79 minute(s)

1 Run a sub-domain/hostname fuzzing scan on "academy.htb" for the IP shown above. What are all the sub-domains you can identify? (Only write the sub-domain name)

archive faculty test

Submit

1 Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

Submit your answer here...

+10 Streak pts Submit Hint

2 One of the pages you will identify should say "You don't have access". What is the full page URL?

Submit your answer here...

+10 Streak pts Submit Hint

Success
Congratulations! You earned 1 cubes!

Hack The Box - Academy VPN Settings x +

https://academy.hackthebox.com/module/54/section/511

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.58.50/41149
Life Left: 69 minute(s)

1 Run a sub-domain/whost fuzzing scan on "academy.htb" for the IP shown above. What are all the sub-domains you can identify? (Only write the sub-domain name)

archive faculty test

Submit

2 Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

php phps php7

Submit Hint

3 One of the pages you will identify should say "You don't have access". What is the full page URL?

Submit your answer here...

Start Instance Success
Congratulations! You earned 1 cubes!
1 / 1 spins left

```
kali@kali -  
File Actions Edit View Help  
[WARN] Caught keyboard interrupt (Ctrl-C)  
  
kali@kali ~$  
kali@kali ~$ ffuf -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://academy.htb:41149/FUZZ -recursion -recursion-depth 1 -e .php,.phps,.php7 -c -ic -t 200 -fs 279  
  
v2.1.0-dev Questions  
  
:: Method : GET  
:: URL : http://academy.htb:41149/FUZZ  
:: Wordlist : FUZZ: /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt  
:: Extensions : .php .phps .php7  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 200  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 279  
  
[Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 159ms]  
index.php [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 156ms]  
:: Progress: [2784/350604] :: Job [1/1] :: 736 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

VPN Settings

https://academy.hackthebox.com/module/54/section/511

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSecAcademy HTBTryHackMe | Dashboard

Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

php.php5.php7

SubmitHint

One of the pages you will identify should say 'You don't have access'. What is the full page URL?

http://faculty.academy.htb:PORT/courses/linux-security.php7

SubmitHint

In the page from the previous question, you should be able to find multiple parameters that are accepted by the page. What are they?

Submit your answer here...

+10 Streak ptsSubmitHint

Try fuzzing the parameters you identified for working values. One of them should return a flag. What is the content of the flag?

Submit your answer here...

+10 Streak ptsSubmitHint

Success

Congratulations! You earned 2 cubes!

kali@kali: ~

File Actions Edit View Help

UserForm [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 157ms]

[WARN] Caught keyboard interrupt (Ctrl-C)

(kali@kali)-[~]

\$ ffuf -w /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://faculty.academy.htb:41149/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -fs 774


v2.1.0-dev

:: Method : POST

:: URL : http://faculty.academy.htb:41149/courses/linux-security.php7

:: Wordlist : FUZZ: /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt

:: Header : Content-Type: application/x-www-form-urlencoded

:: Data : FUZZ=key

:: Follow redirects : false

:: Calibration : false

:: Timeout : 10

:: Threads : 40

:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

:: Filter : Response size: 774

:: Progress: [154/6453] :: Job [1/1] :: 73 req/sec :: Duration: [0:00:01] :: Errors: 0 ::

```
File Actions Edit View Help

(kali@kali)-[~]
$ ffuf -w /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt -u http://faculty.academy.htb:41149/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -fs 774

v2.1.0-dev

:: Method      : POST
:: URL         : http://faculty.academy.htb:41149/courses/linux-security.php7
:: Wordlist    : FUZZ: /home/kali/SecLists/Discovery/Web-Content/burp-parameter-names.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : FUZZ=key
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 774

user [Status: 200, Size: 780, Words: 223, Lines: 53, Duration: 155ms]
username [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 159ms]
:: Progress: [6453/6453] :: Job [1/1] :: 221 req/sec :: Duration: [0:00:39] :: Errors: 0 ::
```

hackthebox.com

https://academy.hackthebox.com/module/54/section/511

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe Dashboard

Submit Hint

2 One of the pages you will identify should say 'You don't have access'. What is the full page URL?

<http://faculty.academy.htb:PORT/courses/linux-security.php7>

Submit Hint

1 In the page from the previous question, you should be able to find multiple parameters that are accepted by the page. What are they?

user username

Submit Hint

2 Try fuzzing the parameters you identified for working values. One of them should return a flag. What is the content of the flag?

Submit your answer here...

+10 Streak pts Submit Hint

Success

✓ Congratulations! You earned 1 cube!

```
File Actions Edit View Help
sunshine [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 154ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

(kali@kali)-[~]
$ ffuf -w /home/kali/SecLists/Usernames/xato-net-10-million-usernames.txt:FUZZ -u http://faculty.academy.htb:41149/courses/linux-security.php7 -X POST -d '
username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 781

v2.1.0-dev

:: Method      : POST
:: URL         : http://faculty.academy.htb:41149/courses/linux-security.php7
:: Wordlist     : FUZZ: /home/kali/SecLists/Usernames/xato-net-10-million-usernames.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : username=FUZZ
:: Follow redirects : false
:: Calibration   : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 781

:: Progress: [113/8295455] :: Job [1/1] :: 67 req/sec :: Duration: [0:00:01] :: Errors: 0 ::

File Actions Edit View Help
sunshine [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 154ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

(kali@kali)-[~]
$ ffuf -w /home/kali/SecLists/Usernames/xato-net-10-million-usernames.txt:FUZZ -u http://faculty.academy.htb:41149/courses/linux-security.php7 -X POST -d '
username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 781

v2.1.0-dev

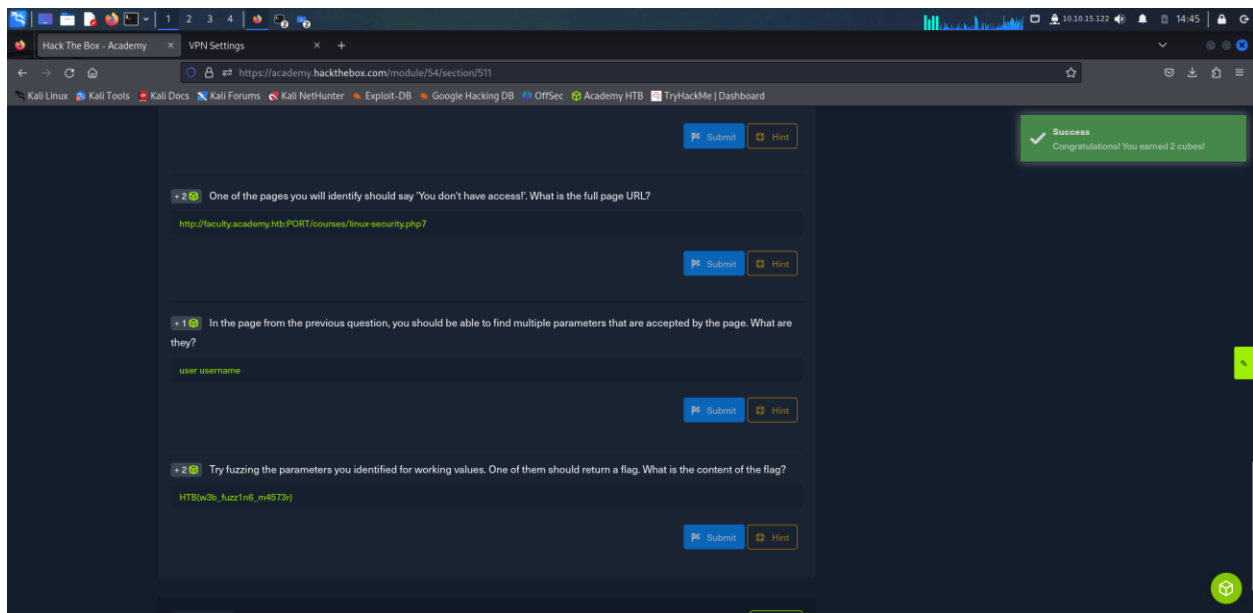
:: Method      : POST
:: URL         : http://faculty.academy.htb:41149/courses/linux-security.php7
:: Wordlist     : FUZZ: /home/kali/SecLists/Usernames/xato-net-10-million-usernames.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : username=FUZZ
:: Follow redirects : false
:: Calibration   : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 781

:: Progress: [134/8295455] :: Job [1/1] :: 54 req/sec :: Duration: [0:00:02] :: Errors: 0 ::
```



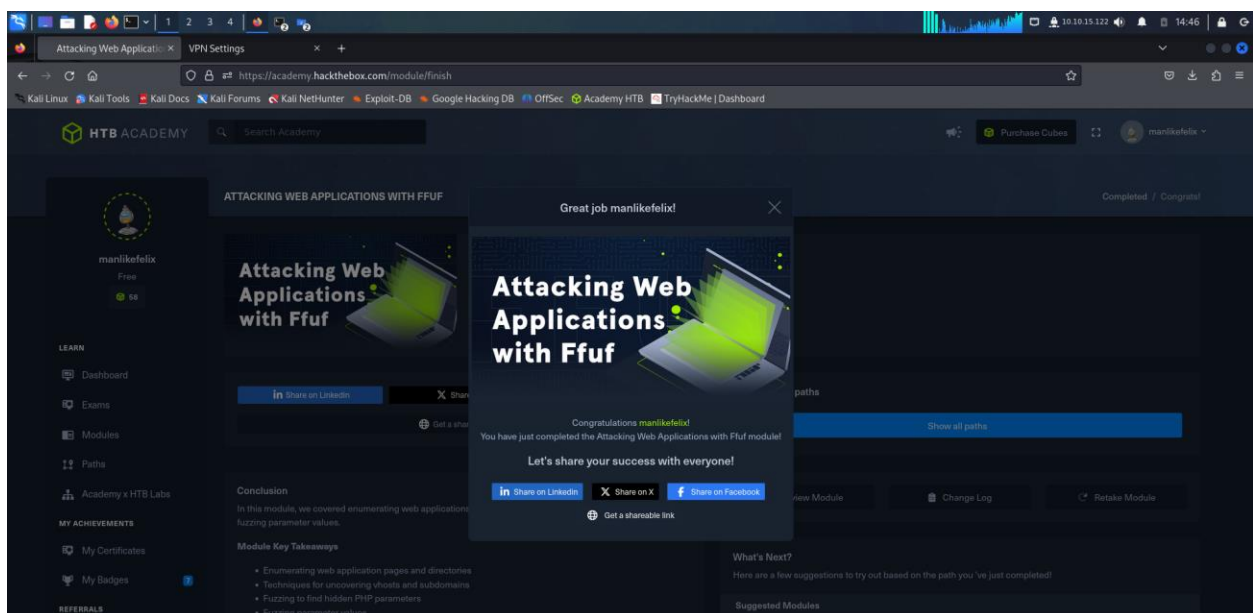
```
kali@kali -  
File Actions Edit View Help  
  
v2.1.0-dev  
  
:: Method      : POST  
:: URL         : http://faculty.academy.htb:41149/courses/linux-security.php7  
:: Wordlist     : FUZZ: /home/kali/SecLists/Usernames/xato-net-10-million-usernames.txt  
:: Header      : Content-Type: application/x-www-form-urlencoded  
:: Data        : username=FUZZ  
:: Follow redirects : false  
:: Calibration  : false  
:: Timeout     : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter      : Response size: 781  
  
harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 153ms]  
Harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 171ms]  
HARRY [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 159ms]  
[WARN] Caught keyboard interrupt (Ctrl-C)  
  
(kali@kali)-[~]  
$
```

```
kali@kali -  
File Actions Edit View Help  
Harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 171ms]  
HARRY [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 159ms]  
[WARN] Caught keyboard interrupt (Ctrl-C)  
  
(kali@kali)-[~]  
$ curl http://faculty.academy.htb:41149/courses/linux-security.php7 -X POST -H 'Content-Type: application/x-www-form-urlencoded' -d 'username=harry'  
<div class='center'><p>HTB{w3b_fuzz1n6_m4573r}</p></div>  
<html>  
<!DOCTYPE html>  
  
<head>  
<title>HTB Academy</title>  
<style>  
*,  
html {  
margin: 0;  
padding: 0;  
border: 0;  
}  
  
html {  
width: 100%;  
height: 100%;  
}  
  
body {  
width: 100%;  
height: 100%;  
position: relative;  
background-color: #151D2B;  
}
```



3. Shareable Link and Final Screenshot

<https://academy.hackthebox.com/achievement/1919044/54>



4. Social Media Posting

https://www.linkedin.com/uas/login?session_redirect=https%3A%2F%2Fwww.linkedin.com%2FshareArticle%3Furl%3Dhttps%3A%2F%2Facademy.hackthebox.com%2Fachievement%2F1919044%2F54%26title%3DCompleted%2520Attacking%2520Web%2520Applications%2520with%2520Ffuf%26summary%3D%2520just%2520completed%2520the%2520module%2520Attacking%2520Web%2520Applications%2520with%2520Ffuf%2520in%2520HTB%2520Academy!%23hackthebox%20#hackthebox%20#htbacademy%20#cybersecurity&source=HTBAcademy

[https://x.com/intent/tweet?url=https://academy.hackthebox.com/achievement/1919044/54&text=I just completed module Attacking Web Applications with Ffuf in HTB Academy!&hashtags=hackthebox,htbacademy,cybersecurity](https://x.com/intent/tweet?url=https://academy.hackthebox.com/achievement/1919044/54&text=I%20just%20completed%20module%20Attacking%20Web%20Applications%20with%20Ffuf%20in%20HTB%20Academy!&hashtags=hackthebox,htbacademy,cybersecurity)

<https://www.facebook.com/sharer/sharer.php?u=https://academy.hackthebox.com/achievement/1919044/54>

5. Conclusion

Completing this module has significantly enhanced my ability to perform thorough web enumeration using Ffuf. I've gained practical experience in uncovering hidden directories, virtual hosts, and vulnerable parameters that could otherwise go unnoticed. The exercises helped solidify my understanding of how attackers think and operate when targeting web applications. Going forward, I feel better equipped to apply these techniques in real-world assessments and appreciate the vital role enumeration plays in the early stages of a penetration test.